

Audit Logging - Developer Guide (How to Log)

Purpose

All audit logging in this project must go through the centralized *AuditLogger* service. This ensures that audit entries are consistent, privacy-safe, and compatible with the existing auditing framework (*owen-it/laravel-auditing*).

Audit events should never be written directly to the *audits* table from controllers.

How to Call the Wrapper

Use the service method:

Pattern

- *AuditLogger::log(eventName, tags, auditableModel, oldValues, newValues)*

Example usage:

Log a successful action:

- event: **report_generated**
- tags: ['reports', 'outcome:success']
- auditable: the affected model (e.g., Report)

What to Pass as the “Auditable” Target

Every audit entry must be attached to a real auditable model so the audit record has *auditable_type* and *auditable_id*.

Use these rules:

Authentication events

- Attach to the authenticated user account.
 - Example: login/logout/register attach to User

User actions

- Attach to the object being changed.
 - Form submission → attach to *FormSubmission*
 - Health goal update → attach to *HealthGoal* (or User)

Researcher actions

- Cohort created → attach to *Cohort*

- Report generated → attach to *Report*
- CSV export → attach to *Report* (or Export record if created)

Provider actions

- Patient record viewed → attach to the participant *User*
- Feedback created → attach to *Feedback* (or User)

Admin actions

- Report deleted → attach to *Report*
- Backup created/restored → attach to *SystemConfiguration*

What Tags to Use (Standard Set)

Tags are used for quick filtering and grouping. Use:

- **one category tag**
- **one outcome tag**

Category tags (choose one)

- **auth**
- **authz**
- **forms**
- **dashboard**
- **reports**
- **exports**
- **cohorts**
- **provider**
- **admin**
- **audit**

Outcome tags (choose one)

- **outcome:success**
- **outcome:failure**
- **outcome:blocked**

Example

- **['auth', 'outcome:success']**
- **['exports', 'outcome:success']**

- ['cohorts', 'outcome:blocked']

What Can and Cannot Be Logged (Privacy Rules)

Allowed in audit metadata (**old_values/new_values**)

- IDs (user_id, report_id, cohort_id)
- event codes and flags
- non-sensitive settings values (e.g., “report_type=aggregate”)

Never log

- raw health values or symptoms
- full form responses
- free-text provider notes
- direct identifiers (name, email, address, DOB)

If sensitive content is required for debugging, it must be handled in development logs only (not audit logs) and removed before deployment.

Quick “When to Log” Guidance

Log an audit entry when:

- authentication succeeds/fails
- a report is generated/exported
- a cohort is created/used
- any admin moderation occurs
- data access occurs (especially provider access)
- privacy rules block an action (k-threshold suppression)